

บทที่ 6 : ความมั่นคงปลอดภัย ทางด้านคอมพิวเตอร์

- สามเสาหลักด้านความมั่นคงปลอดภัย (CIA Triad)
- เปรียบเทียบ TCP/IP Model กับ OSI Model
- Malware/Social Engineering
- ความเสี่ยงด้านความปลอดภัยของเว็บแอปพลิเคชัน
- ใบรับรองด้านความมั่นคงปลอดภัย
- แบบฝึกหัด



1. สามเสาหลักด้านความมั่นคงปลอดภัย (CIA Triad)

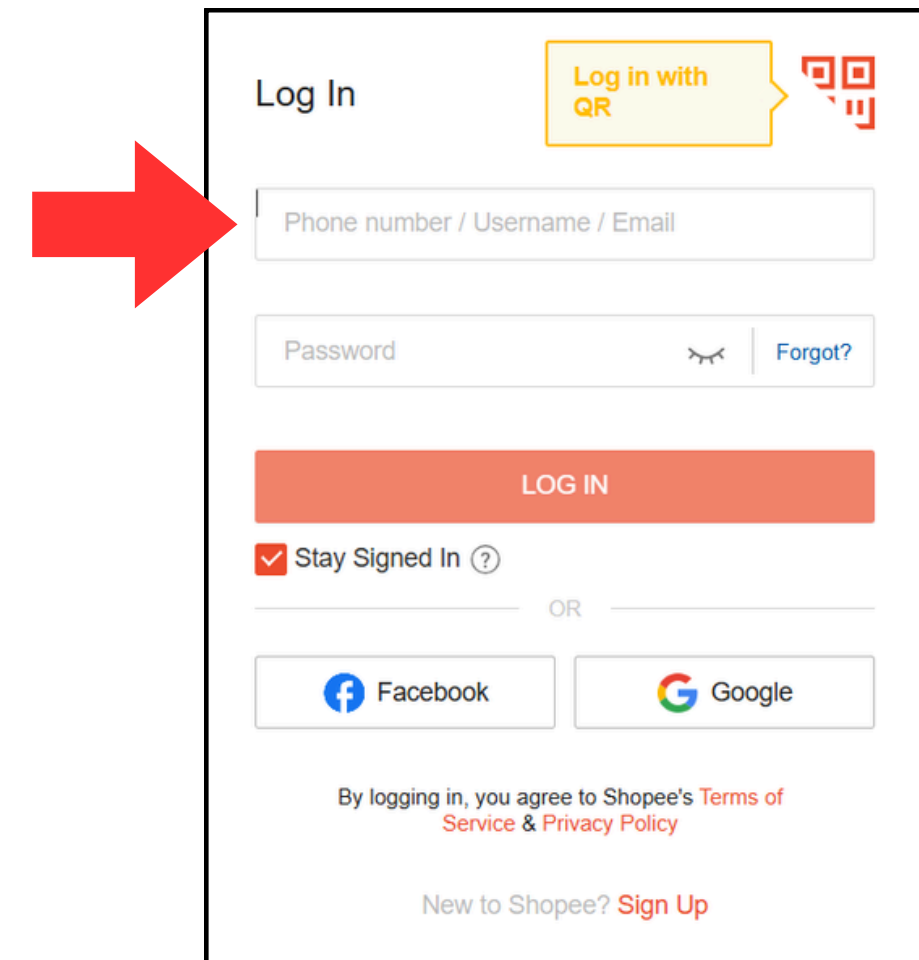
องค์ประกอบ	วัตถุประสงค์	ตัวอย่าง
Confidentiality (การรักษาความลับ)	รักษาความลับของข้อมูล	การควบคุมการเข้าถึง (Access Control), การเข้ารหัส (Encryption)
Integrity (การรักษาความถูกต้องสมบูรณ์)	รักษาความถูกต้องและ ความครบถ้วนของข้อมูล	ลายเซ็นดิจิทัล (Digital Signatures), การตรวจสอบความถูกต้องของข้อมูล (Checksums), การควบคุมเวอร์ชัน (Version Control)
Availability (ความพร้อมใช้งาน)	ทำให้ระบบและข้อมูลพร้อมใช้งานเสมอ	การป้องกันการโจมตีแบบ DDoS (DDoS Protection), การสำรองและกู้คืนข้อมูล (Backup/Recovery), การกู้คืนระบบจากภัยพิบัติ (Disaster Recovery)

- องค์ประกอบของ การควบคุมการเข้าถึง (Access Control)

Identification (การระบุตัวตน) เป็นการบอกว่า "ฉันคือใคร" ยังไม่ได้พิสูจน์ว่าเป็นจริงหรือไม่

ตัวอย่าง

- กรอก Username
- กรอก Email
- กรอก Employee ID
- พิมพ์เลขบัตรประชาชน
- แตะบัตรพนักงานที่ประตู



The image shows a login interface for Shopee. At the top left is the text "Log In". To its right is a yellow box with the text "Log in with QR" and a QR code icon. Below these is a large input field with the placeholder text "Phone number / Username / Email". A red arrow points from the left towards this input field. Below the input field is a password field with the placeholder "Password", an eye icon to toggle visibility, and a "Forgot?" link. Below the password field is a red "LOG IN" button. Underneath the button is a checkbox labeled "Stay Signed In" with a question mark icon. Below this is a horizontal separator with "OR" in the center. At the bottom of the login section are two buttons: "Facebook" with the Facebook logo and "Google" with the Google logo. At the very bottom, there is a line of text: "By logging in, you agree to Shopee's Terms of Service & Privacy Policy". Below that is a link: "New to Shopee? Sign Up".

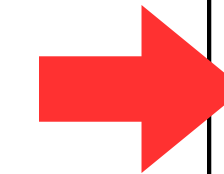
Authentication (การพิสูจน์ตัวตน) เป็นการพิสูจน์ว่า "คุณเป็นคนนั้นจริงหรือไม่"

- **ปัจจัย (Factor) ที่ใช้ในการพิสูจน์ตัวตน**

1. การพิสูจน์ตัวตนจากสิ่งที่รู้ (Something You Know) เช่น Password, PIN
2. การพิสูจน์ตัวตนจากสิ่งที่มี (Something You Have) เช่น Key Card, OTP
3. การพิสูจน์ตัวตนจากสิ่งที่ เป็น (Something You Are) เช่น ลายนิ้วมือ, ใบหน้า
4. อื่น ๆ เช่น เวลา, สถานที่

- **รูปแบบการพิสูจน์ตัวตน**

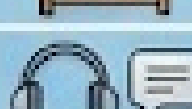
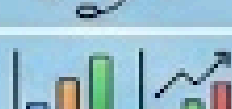
- Two-factor authentication (2FA) : ใช้ 2 Factors ในการพิสูจน์ตัวตน
- Multi-Factor Authentication (MFA) : ใช้หลาย Factors ในการพิสูจน์ตัวตน

A screenshot of the Shopee login page. It features a 'Log In' header, a 'Log in with QR' button, and input fields for 'Phone number / Username / Email' and 'Password'. There is a 'LOG IN' button, a 'Stay Signed In' checkbox, and social login options for Facebook and Google. At the bottom, it includes a link to the Terms of Service and Privacy Policy, and a 'Sign Up' link for new users.

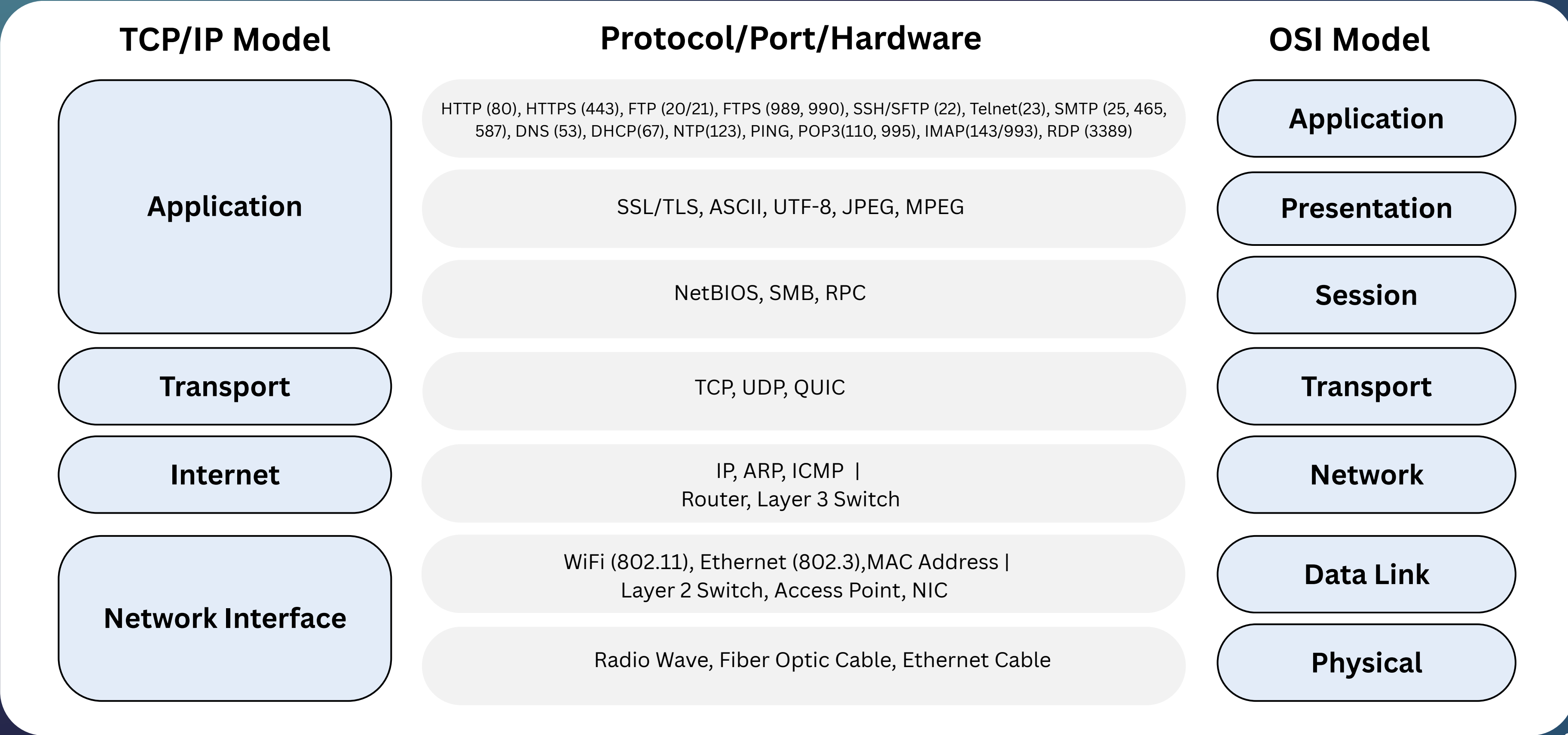
Authorization (การให้สิทธิ์) โดยหลังพิสูจน์แล้วว่า เป็นใคร ระบบจะให้สิทธิ์ "คนนี้จะทำอะไรได้บ้าง"

การให้สิทธิ์มักเกิดขึ้นหลังจากพิสูจน์สำเร็จ หรือ Login เสร็จแล้วทันทีในทุก ๆ ครั้ง ส่วน**การบริหารจัดการสิทธิ์ (Permission Management)** เพื่อระบุว่าใครควรมีสิทธิ์อะไรบ้างหรือเข้าเมนูไหนได้บ้างมักต้องดำเนินการไว้ก่อน

ตัวอย่างการบริหารจัดการสิทธิ์

SYSTEM MENU		 CUSTOMER	 EMPLOYEE	 MANAGER
	HOME PAGE	✓	✓	✓
	PRODUCT LISTINGS	✓	✓	✓
	SHOPPING CART	✓	✗	✗
	ORDER HISTORY	✓	✓	✓
	PROFILE SETTINGS	✓	✓	✓
	PRODUCT MANAGEMENT	✗	✗	✓
	ORDER PROCESSING	✗	✓	✓
	INVENTORY MANAGEMENT	✗	✓	✓
	CUSTOMER SERVICE TICKETS	✗	✓	✓
	REPORTING & ANALYTICS	✗	ANALYTICS (view only, not create)	✓
	SYSTEM SETTINGS	✗	✗	✓

2. เปรียบเทียบ TCP/IP Model กับ OSI Model



3. Malware/Social Engineering

- Malware (Malicious)

Item	Category	Description	How it works / Examples
1	Virus	ไวรัสคอมพิวเตอร์ เป็นมัลแวร์ที่แนบตัวเองไปกับไฟล์หรือโปรแกรม	จะแพร่กระจายเมื่อเปิดไฟล์/รันโปรแกรมที่ติดไวรัส เช่น ไฟล์ .exe, .xlsm
2	Worm	หนอนคอมพิวเตอร์ แพร่กระจายตัวเองผ่านเครือข่ายโดยไม่ต้องพึ่งไฟล์	ใช้ช่องโหว่ของระบบ เช่น อีเมล หรือการแชร์ไฟล์ในเครือข่าย
3	Ransomware	มัลแวร์เรียกค่าไถ่ เข้ารหัสไฟล์ของผู้ใช้และเรียกเงินเพื่อปลดล็อก	เช่น WannaCry, Locky
4	Trojan	โทรจัน เป็นโปรแกรมที่ดูเหมือนปกติ แต่แอบเปิดช่องโหว่ (Backdoor) ให้แฮกเกอร์เข้ามา	เช่น โปรแกรมฟรีที่ซ่อน backdoor
5	Spyware	สปายแวร์ แอบเก็บข้อมูลผู้ใช้โดยไม่รู้ตัว เช่น รหัสผ่าน, พฤติกรรมการใช้งาน แล้วส่งกลับไปยังแฮกเกอร์	มักมาพร้อมกับฟรีแวร์หรือไฟล์แนบ
6	Adware	แอดแวร์ เป็น popup โฆษณาที่ไม่ต้องการ มักพบในเว็บไซต์พนัน เว็บไซต์ลามก หรือแฝงมากับการติดตั้งโปรแกรมฟรี	เช่น Popup โฆษณาที่ถ้าปิดแล้วจะเปิดใหม่เองเรื่อย ๆ
7	Rootkit	รูตคิต ซ่อนตัวเองและซ่อนมัลแวร์อื่น (เช่น Trojan) ในระบบ เพื่อให้แฮกเกอร์เข้าถึงสิทธิ์ระดับสูงโดยไม่ถูกตรวจจับ	ยากต่อการตรวจจับ ปกติใช้คู่กับมัลแวร์อื่น

• Social Engineering

Item	Category	Description	How it works / Examples
1	Phishing	เป็นการหลอกลวงผ่าน อีเมล เป็นหลัก ที่มีเป้าหมายเพื่อหลอกให้เหยื่อคลิกลิงก์ไปยัง เว็บไซต์ปลอม	ส่งอีเมลปลอมเป็นธนาคาร/บริษัท เพื่อหลอกให้ผู้ใช้กรอกรหัสผ่าน หรือเลขบัตรเครดิต
2	Vishing	เป็นการหลอกลวงผ่านโทรศัพท์ ถือเป็นรูปแบบหนึ่งของ Phishing มาจากคำว่า Voice Phishing	โทรเข้าผู้ใช้ปลอมตัวเป็นเจ้าหน้าที่ธนาคาร ขอ รหัส OTP หรือข้อมูลบัญชี
3	Smishing	เป็นการหลอกลวงผ่าน SMS ถือเป็นรูปแบบหนึ่งของ Phishing มาจากคำว่า SMS Phishing	ส่ง SMS ปลอมเช่น “คุณได้รับรางวัล คลิกที่นี่” เพื่อหลอกให้คลิกลิงก์หรือดาวน์โหลดไฟล์ที่มี malware
4	Deepfake Phishing	เป็นการหลอกลวงด้วยการปลอมแปลงใบหน้าให้เหมือนกับคนที่รู้จักหรือเหมือนกับเจ้าหน้าที่รัฐ โดยใช้เทคโนโลยี Deepfake	ปลอมเป็นลูกแล้วให้พ่อแม่โอนเงินให้
5	Baiting	เป็นการหลอกลวงผ่านการดึงดูด	ให้ใช้โปรแกรมในการ Crack Password ฟรี แต่แอบฝัง malware ไว้ในโปรแกรม

Clickbait คือ การเขียนหัวข้อเกินจริง (หรือภาพที่เกินจริง) เพื่อกระตุ้นให้คนคลิกเข้าไปอ่านหรือดูต่อ

4. ความเสี่ยงด้านความปลอดภัยของเว็บแอปพลิเคชัน

• Top 10 Web Application Security Risks (OWASP Top 10 : 2021)

Item	Risk/Vulnerability	Description	Prevention
1	Broken Access Control	การควบคุมสิทธิ์ไม่ถูกต้อง ผู้โจมตีสามารถเข้าถึงฟังก์ชันหรือข้อมูล ที่ไม่ได้รับอนุญาต	ตรวจสอบสิทธิ์การเข้าถึง API ด้วย access token, ตรวจสอบสิทธิ์บน server-side, ไม่เก็บสิทธิ์ใน client-side
2	Cryptographic Failures	การเข้ารหัสหรือการจัดการข้อมูลลับไม่ถูกต้อง ทำให้ข้อมูลรั่วไหล	ใช้การเข้ารหัสที่ปลอดภัย (เช่น SSL/TLS), เก็บรหัสผ่านด้วย hashing เช่น bcrypt
3	Injection	การป้อนข้อมูลหรือโค้ดที่ไม่ปลอดภัย เช่น การโจมตีแบบ SQL Injection, LDAP Injection หรือ OS Command Injection	ใช้ prepared statements, ORM, Sanitize input
4	Insecure Design	การออกแบบระบบไม่ปลอดภัยจากต้นทาง เช่น ไม่มี threat modeling	ใช้ secure design principles, threat modeling, defense-in-depth

Item	Risk/Vulnerability	Description	Prevention
5	Security Misconfiguration	การตั้งค่าระบบหรือแอปพลิเคชันไม่ปลอดภัย ทำให้ผู้โจมตีสามารถเข้าถึงข้อมูลหรือควบคุมระบบได้	ไม่ใช่ default password, ไม่เปิด port โดยไม่จำเป็น, ไม่เปิด debug mode
6	Vulnerable and Outdated Components	การใช้ software, component, library, หรือ framework ที่มีช่องโหว่ หรือล้าสมัย	อัปเดตให้เป็นเวอร์ชันล่าสุด, ใช้ vulnerability scanning tools
7	Identification and Authentication Failures	ความล้มเหลวในการระบุและยืนยันตัวตนของผู้ใช้งาน	ใช้ MFA, strong password , กำหนด rate-limit, session timeout ยาวเกินไป
8	Software and Data Integrity Failures	ความล้มเหลวในการตรวจสอบความถูกต้องและความสมบูรณ์ของซอฟต์แวร์และข้อมูล	ใช้ code signing, checksum validation, update verification
9	Security Logging and Monitoring Failures	ขาดการบันทึกหรือเฝ้าระวัง ทำให้โจมตีไม่ถูกตรวจจับ	ทำ centralized logging, monitor suspicious activities, alert system
10	Server-Side Request Forgery (SSRF)	ผู้โจมตีบังคับ server ทำ request ไปยัง internal system	ตรวจสอบ input URL, whitelist domains, block internal IPs

• Top 10 kali tools (For Pentation Test)

Item	Tool	Category	Primary Purpose	Common Use Case
1	aircrack-ng	Wireless Network Tools	Cracking WEP/WPA/WPA2-PSK wireless network passwords.	Auditing wireless networks, cracking wireless keys, capturing and analyzing packets.
2	burpsuite	Web Application Tools	Comprehensive web vulnerability scanning and exploitation tool.	Testing web apps for vulnerabilities (e.g., XSS, SQL injection), intercepting HTTP requests/responses.
3	hydra	Password Cracking	Fast network logon cracker supporting many protocols.	Performing brute-force attacks on services like SSH, FTP, HTTP, and more.
4	john	Password Cracking	Offline password cracking tool ("John the Ripper").	Cracking password hashes from files (e.g., /etc/shadow), auditing weak passwords.

Item	Tool	Category	Primary Purpose	Common Use Case
5	metasploit-framework	Exploitation Framework	Advanced penetration testing and exploitation tool.	Finding and exploiting vulnerabilities in systems, automating attacks, post-exploitation actions.
6	netcat (netexec)	Networking	Utility for reading/writing data across networks.	Banner grabbing, port scanning, creating reverse/forward shells, transferring files.
7	nmap	Network Scanning	Network discovery and security auditing.	Scanning networks for open ports/services, detecting OS, vulnerability detection, network mapping.
8	responder	Network Tools	Network spoofing tool for man-in-the-middle attacks.	Capturing credentials on networks using techniques like LLMNR and NBT-NS spoofing.

Item	Tool	Category	Primary Purpose	Common Use Case
9	sqlmap	Web Application Tools	Automated tool for SQL injection and database takeover.	Exploiting SQL injection vulnerabilities to extract data, take over databases, or execute commands.
10	wireshark	Network Analysis	Network protocol analyzer for traffic capture and inspection.	Capturing and analyzing network traffic, troubleshooting network issues, protocol analysis.

5. ใบรับรองด้านความมั่นคงปลอดภัย

- ใบรับรองสำหรับองค์กร (Organization Certifications)

Item	Standard	Description
1	ISO/IEC 27001 Certification	มาตรฐานการจัดการความมั่นคงปลอดภัยของข้อมูล (Information Security Management System - ISMS)
2	CSA-STAR	Cloud Security Alliance (CSA) – Security, Trust & Assurance Registry (STAR)



• ใบรับรองสำหรับบุคคล (Professional Certifications)

Item	Standard	Suitable For	By
1	Security +	เหมาะกับ ผู้เริ่มต้นในสายงาน Security	สถาบัน CompTIA
2	Systems Security Certified Practitioner (SSCP)	เหมาะกับ ผู้ปฏิบัติการ Security Analyst	ISC ²
3	Certified Information System Auditor (CISA)	เหมาะกับ IT Auditor, IT Risk	ISACA
4	Certified Information Security Manager (CISM)	เหมาะกับ ผู้จัดการ/ผู้บริหารด้าน Security และ Risk	ISACA
5	Certified Information Systems Security Professional (CISSP)	เหมาะกับ ผู้เชี่ยวชาญ	ISC ²
6	GIAC Certification	เหมาะกับ ผู้เชี่ยวชาญ	GIAC Global

Security+ → SSCP → CISA / CISM → CISSP → GIAC

6. แบบฝึกหัด

1. การโจมตีด้วยมัลแวร์เรียกค่าไถ่ (Ransomware) ที่ทำการเข้ารหัสไฟล์ของผู้ใช้ ส่งผลกระทบต่อหลักการ CIA Triad เสาหลักใดมากที่สุด (ระหว่าง Confidentiality, Integrity หรือ Availability) และองค์กรควรใช้มาตรการใดจากหลักการนี้เพื่อรับมือกับเหตุการณ์ดังกล่าว
2. หากระบบเกิดช่องโหว่เว็บแอปพลิเคชันประเภท Broken Access Control ซึ่งผู้โจมตีเข้าถึงข้อมูลที่ไม่ได้รับอนุญาต ความผิดพลาดนี้สะท้อนให้เห็นถึงความล้มเหลวในขั้นตอนการ Authentication (การพิสูจน์ตัวตน) หรือการ Authorization (การให้สิทธิ์)
3. Multi-Factor Authentication (MFA) ช่วยป้องกัน Phishing หรือ Vishing ได้อย่างมีประสิทธิภาพหรือไม่
4. ปัจจัยด้านไบโอเมตริกซ์ (Something You Are) เช่น ใบหน้า สามารถถูกหลอกลวงด้วยเทคนิค Deepfake Phishing ได้อย่างไร
5. หากนักวิเคราะห์ความปลอดภัยใช้เครื่องมือ Wireshark เพื่อดักจับและวิเคราะห์กราฟฟิคในระบบเครือข่าย พวกเขากำลังวิเคราะห์ข้อมูลในระดับชั้น (Layer) ใดเป็นหลัก และมีความแตกต่างจากการใช้เครื่องมือ Burpsuite หรือ Sqlmap อย่างไร
6. ระหว่าง Worm กับ Trojan มัลแวร์ชนิดใดมีความเสี่ยงที่จะสร้างความเสียหายเป็นวงกว้างได้รวดเร็วกว่า หากเครือข่ายนั้นมีช่องโหว่ประเภท Vulnerable and Outdated Components

- 7.ระหว่างช่องโหว่ประเภท Insecure Design และ Security Misconfiguration จงวิเคราะห์ว่าช่องโหว่ใดแก้ไขได้ยากกว่ากันหลังจากที่ระบบถูกพัฒนาเสร็จสิ้นแล้ว
- 8.การประยุกต์ใช้ Kali Tools กับช่องโหว่ด้านการพิสูจน์ตัวตน หากองค์กรพบช่องโหว่ประเภท Identification and Authentication Failures ผู้ทดสอบเจาะระบบ (Penetration Tester) ควรเลือกใช้เครื่องมือใดในกลุ่ม Kali Tools เพื่อจำลองการโจมตี (Brute-force หรือ Password Cracking) และองค์กรควรใช้มาตรการใดในการป้องกัน
- 9.หากองค์กรต้องการนำข้อมูลขึ้นระบบคลาวด์ องค์กรควรเลือกขอใบรับรองมาตรฐานใดระหว่าง ISO/IEC 27001 หรือ CSA-STAR เพื่อสร้างความน่าเชื่อถือด้านความปลอดภัยบนคลาวด์ และหากองค์กรต้องการจ้างบุคคลเพื่อบริหารจัดการความเสี่ยง (Risk Management) โดยตรง ควรพิจารณาผู้ที่ถือใบรับรอง CISA, CISM หรือ CISSP จึงจะเหมาะสมกับระดับการทำงานมากที่สุด
10. ในการป้องกันความเสี่ยงประเภท Software and Data Integrity Failures การใช้ Checksums มีกลไกช่วยยืนยันได้อย่างไรว่าการอัปเดตซอฟต์แวร์หรือ Libraries ต่าง ๆ ไม่ได้ถูกแฮกเกอร์ฝังมัลแวร์หรือดัดแปลงระหว่างทาง

11. หากพบว่ามี การดักจับข้อมูลระหว่างการสมัครสมาชิกของแพลตฟอร์มซื้อขายออนไลน์ ซึ่งผู้ดักจับได้นำข้อมูลไปเผยแพร่ และมีผู้นำข้อมูลที่ได้จากการเผยแพร่ไปใช้ในการส่งสแปมเมล จงตอบคำถามต่อไปนี้

11.1 ผู้ทำการดักจับข้อมูลต้องได้รับโทษจาก พ.ร.บ. อะไรบ้าง มาตราไหนบ้าง และโทษอย่างไรบ้าง

11.2 ผู้ส่งสแปมเมลต้องได้รับโทษจาก พ.ร.บ. อะไรบ้าง มาตราไหนบ้าง และโทษอย่างไรบ้าง

11.3 เจ้าของแพลตฟอร์มต้องแจ้งใครบ้าง และแจ้งภายในกี่ชั่วโมง

11.4 เจ้าของแพลตฟอร์มต้องได้รับโทษจาก พ.ร.บ. อะไรบ้าง มาตราไหนบ้าง และโทษอย่างไรบ้าง

11.5 เจ้าของข้อมูลส่วนบุคคลต้องร้องเรียนกับใครบ้าง

11.6 จงวิเคราะห์ว่าแพลตฟอร์มนี้มีช่องโหว่อะไรบ้างและต้องแก้ไขอย่างไร

12. หากพบว่ามีผู้โจมตีทำการโจมตีในรูปแบบ DDoS (Distributed Denial of Service) ไปยังเครื่อง Server ของแพลตฟอร์มซื้อขายออนไลน์ ด้วยวิธีการ Ping Flood และ HTTP Flood (F5) จนแพลตฟอร์มซื้อขายออนไลน์ ไม่สามารถให้บริการได้ จงตอบคำถามต่อไปนี้

12.1 ผู้โจมตีมีความผิด พ.ร.บ. อะไรบ้าง มาตราไหนบ้าง และมีโทษอย่างไร

12.2 มีวิธีป้องกันการโจมตีในลักษณะนี้ได้หรือไม่

THANK YOU FOR YOUR ATTENTION



Contact Me:

 ห้อง 970

 pichai_jo@rmutto.ac.th

 busit.rmutto.ac.th

